

Lista de Exercícios 2

Disciplina: ADS309 – Segurança e Confiabilidade de Sistemas

Professor: Fabiano Mario Rodrigues Fialho

Aluno: Bernardo Cordeiro Motta — Matrícula: 26351

1º semestre 2026 — Entrega: 16/06

1 — Defina o que é uma política de segurança da informação. Qual é o seu principal objetivo?

É o documento formal, aprovado pela direção da empresa, que define as regras e diretrizes sobre como os ativos de informação devem ser protegidos. Ela serve de base para todo o programa de segurança, deixando claro o que se espera dos usuários e quais são os limites de uso dos recursos de TI.

O objetivo principal é proteger a informação contra ameaças internas e externas, garantindo a continuidade do negócio e mantendo a confidencialidade, a integridade e a disponibilidade dos dados da organização.

2 — Quais são as 3 áreas de normalização da política de segurança da informação? O que deve ser abrangido em cada uma delas?

Segurança Organizacional — é a estrutura de gestão que coordena a implementação da segurança na empresa, definindo papéis, responsabilidades, comitês de segurança e o relacionamento com fornecedores e terceiros.

Classificação e Controle dos Ativos de Informação — consiste em mapear os ativos da empresa (dados, sistemas, equipamentos), definir quem é responsável por cada um e classificá-los por nível de sensibilidade, para que cada um receba a proteção adequada.

Segurança em Pessoas — envolve as práticas ligadas a recursos humanos, como verificação na contratação, termos de confidencialidade, treinamentos de conscientização e os procedimentos para casos de violação de normas ou desligamento.

3 — Dentre os documentos da política de segurança da informação temos as diretrizes, as normas e os procedimentos. Discorra sobre cada um desses documentos destacando onde são aplicadas.

Diretrizes — são declarações mais genéricas e estratégicas, que mostram a intenção da organização em relação à segurança. Valem para a empresa como um todo e servem de base para os demais documentos.

Normas — detalham regras específicas para que as diretrizes sejam cumpridas, dizendo o que pode ou não ser feito. São aplicadas a áreas ou grupos específicos, como uma norma de uso de senhas, por exemplo.

Procedimentos — são o "passo a passo" de como executar uma norma na prática. Atuam no dia a dia, orientando tecnicamente quem vai realizar a tarefa.

4 — Referente aos princípios básicos da segurança da informação. Defina o que se pede:

a) Confidencialidade — garantir que só pessoas autorizadas tenham acesso à informação, evitando que dados sensíveis cheguem a quem não deveria.

b) Autenticidade — ter certeza de que a informação realmente veio de quem diz ter enviado, confirmando a origem dos dados.

c) Integridade — assegurar que a informação continua completa e exata, sem ser alterada ou corrompida sem autorização.

d) Disponibilidade — garantir que a informação esteja acessível sempre que os usuários autorizados precisarem dela.

5 — Responda o que se pede:

a) Criptografia — técnica que usa algoritmos para transformar uma informação legível em um conteúdo embaralhado, que só pode ser revertido por quem tem a chave certa. Seu foco principal é garantir a confidencialidade.

b) Esteganografia — técnica que esconde a existência de uma mensagem dentro de outro arquivo, como uma imagem ou um áudio. Diferente da criptografia, aqui ninguém percebe nem que há algo escondido.

6 — Referente aos conceitos de criptografia, responda o que se pede:

a) Chaves simétricas — usam a mesma chave para cifrar e decifrar a informação, sendo necessário que emissor e receptor compartilhem essa chave previamente. Exemplos: DES, 3DES e AES.

b) Vantagens e desvantagens — a grande vantagem é a velocidade, ideal para grandes volumes de dados. A desvantagem é o risco na hora de compartilhar a chave: se ela for interceptada, toda a segurança cai.

c) Chaves assimétricas — usam um par de chaves: uma pública, que pode circular livremente, e uma privada, mantida em sigilo. O que é cifrado com uma só pode ser aberto com a outra. Exemplos: RSA, ECC e Diffie-Hellman.

d) Vantagens e desvantagens — resolve o problema da troca de chaves e permite assinatura digital, mas em troca é bem mais lenta que a simétrica, não sendo ideal para grandes volumes de dados.

e) Modelo híbrido — junta o melhor dos dois mundos: usa a criptografia assimétrica só para trocar com segurança uma chave simétrica, e depois toda a comunicação passa a usar essa chave simétrica, que é mais rápida.

f) Assinatura digital — o emissor gera um hash da mensagem e o cifra com sua chave privada. Quem recebe usa a chave pública do emissor para decifrar e comparar com um novo hash calculado. Se forem iguais, confirma-se que a mensagem é autêntica e não foi alterada.

7 — Referente às fraudes eletrônicas, responda o que se pede:

a) Como funciona a fraude por engenharia social — em vez de explorar falhas técnicas, o criminoso explora a confiança e a urgência da vítima, geralmente se passando por funcionário de banco ou de órgão público, para convencê-la a fornecer dados sigilosos ou fazer uma transferência sem ter tempo de checar se aquilo é real.

b) Fraudes eletrônicas de maior ocorrência no Brasil atualmente — entre as mais comuns estão o phishing, a clonagem de WhatsApp, os golpes de falsa central telefônica (criminosos se passando por atendentes de banco) e os golpes em compras on-line e via Pix. Mais recentemente, também vêm crescendo fraudes com deepfakes de voz e vídeo para burlar sistemas de autenticação.

8 — Sobre o controle de acesso, responda o que se pede:

a) Controle de acesso — conjunto de mecanismos usados para definir quem pode acessar determinados recursos de uma organização. Seu objetivo é garantir que só usuários autorizados acessem o que precisam, protegendo a confidencialidade e a integridade das informações e permitindo rastrear os acessos feitos.

b) Privilégio mínimo — princípio de dar a cada usuário apenas o acesso mínimo necessário para sua função, nada além disso. Assim, se uma conta for comprometida, o estrago fica limitado ao que ela realmente podia acessar.

c) Gerenciamento de acesso do usuário — deve incluir o registro e cancelamento de usuários, a concessão e revisão periódica de privilégios, o gerenciamento de senhas e a análise crítica regular dos acessos, para que ninguém fique com permissões que não precisa mais.

d) Controle de acesso à rede, ao sistema operacional e à aplicação/informação:

- **À rede:** controla quem pode se conectar à infraestrutura, usando firewalls, segmentação e autenticação para acesso remoto.
- **Ao sistema operacional:** garante que só usuários autenticados consigam fazer login nos equipamentos.
- **À aplicação e à informação:** restringe, dentro de cada sistema, o que cada usuário pode ver ou alterar.

9 — Sobre a norma ISO 27001, responda o que se pede:

a) Norma ISO 27001 — norma internacional que estabelece os requisitos para implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI). É a norma certificável da família 27000.

b) SGSI — sigla para Sistema de Gestão de Segurança da Informação, parte da gestão da empresa responsável por organizar, monitorar e melhorar a segurança da informação com base em uma análise de riscos.

c) Sistema de gestão de segurança da informação — é uma abordagem baseada em ciclo de melhoria contínua (planejar, fazer, verificar e agir) para gerenciar os riscos de segurança da informação, envolvendo pessoas, processos e tecnologia de forma integrada.

d) Antes da implantação de um SGSI — é preciso definir o escopo do sistema, identificar e avaliar os riscos, conseguir o apoio formal da alta direção, definir a política de segurança e levantar os requisitos legais e contratuais aplicáveis ao negócio.

10 — Defina o que se pede:

a) Norma ISO 27002 — norma complementar à ISO 27001 que reúne boas práticas para escolher e implementar controles de segurança. Enquanto a 27001 define os requisitos do SGSI, a 27002 mostra como colocá-los em prática, funcionando como um guia técnico, não como uma norma certificável.

b) O que deve ser tratado na norma ISO 27002 — a norma detalha os controles de segurança da informação, organizados em quatro temas: organizacionais, de pessoas, físicos e tecnológicos. Para cada um, ela explica a finalidade e como implementá-lo, cobrindo áreas como gestão de ativos, controle de acesso, criptografia, segurança física, relacionamento com fornecedores e gestão de incidentes.